

NETWORKWALKS

CYBERSECURITY INTERNSHIP

MEDIROZA GENERAL HOSPITAL

PENETRATION TESTING REPORT

Batch B082 | Week 4 | M4

Prepared by Antoinette Thompson
Final status update: 9 September 2026

CONFIDENTIAL / AUTHORIZED TRAINING ENVIRONMENT

This report documents testing performed only against the authorized NetworkWalks training target. Patient information, credentials, hashes, national identifiers, salary values and other unnecessary confidential values are intentionally redacted.

1. Executive Summary

This report presents the final results of the Week 4 black-box penetration-testing exercise against the authorized Mediroza General Hospital web application. The assessment objectives were to obtain three confidential patient PDF laboratory reports (M1), recover their passwords (M2), identify employee salary and shareholder information (M3), and document the work professionally (M4). The project instructions explicitly required proof of exploitation and a professional client-facing report.

All four milestones were ultimately achieved. M1 was completed through an authentication-bypass SQL injection discovered during manual testing after earlier automated testing had not identified the weakness. The successful input used the username value `admin'--` with a non-empty password, resulting in authenticated access to the patient reports area. Three PDF files were then downloaded. M2 was completed by extracting crackable PDF hashes and using dictionary-based password recovery; all three files were successfully opened. M3 had already been achieved earlier in the exercise through direct access to an exposed SQL database backup, revealing staff salary-related fields and shareholder structures. M4 is this final report.

OVERALL RISK: CRITICAL

The combination of an authentication-bypass vulnerability exposing confidential patient reports and a publicly retrievable database backup containing highly sensitive employee information creates a critical overall security condition. Immediate remediation should prioritize removal of exposed backups and correction of unsafe SQL handling.

Milestone Status — Final

Milestone	Objective	Final Result	Status
M1 — Initial Access	Retrieve 3 confidential patient PDF lab reports	Authenticated to Patient Portal using SQL injection; 3 PDFs downloaded	COMPLETED
M2 — Data Extraction	Crack encryption on all 3 retrieved files	All 3 PDF passwords recovered and files opened	COMPLETED
M3 — Attack / Cracking	Find employee salaries and shareholder details	Exposed SQL backup analyzed; staff and shareholder structures/data confirmed	COMPLETED
M4 — Report	Produce professional pentest report	Final report, evidence register, redacted screenshots and remediation	COMPLETED

2. Scope, Authorization and Rules of Engagement

The project brief states that this was a full black-box penetration test and vulnerability assessment against the Mediroza General Hospital target. Written authorization was granted, testing was limited to the target domain, and the rules prohibited social engineering, denial-of-service activity and testing outside the agreed scope. The exercise duration was three days.

- Target: medirozahospital.com
- Assessment type: Black-box penetration testing and vulnerability assessment
- Environment: NetworkWalks authorized educational environment
- Restrictions: Target domain only; no social engineering; no denial of service; no out-of-scope testing
- Evidence: Chronological screenshot workbook plus local test artifacts

3. Assessment Objectives

The Week 4 milestone brief defined the four objectives as follows: M1 required retrieval of three confidential patient PDFs; M2 required recovery of the encryption/password on all three; M3 required discovery of hospital employee salaries and shareholder details; and M4 required a professional penetration-testing report.

4. Methodology and Tools

Testing progressed iteratively rather than as a single automated scan. The evidence shows reconnaissance, service and technology identification, web enumeration, HTML/application-route inspection, authentication-response comparison, manual input testing, controlled credential testing, backup retrieval, database-structure review, PDF hash extraction, dictionary password recovery and evidence preservation.

4.1 Tools and techniques evidenced in the assessment

- WHOIS — domain registration/reconnaissance (workbook p.1).
- nslookup — DNS resolution checks (workbook p.2).
- WhatWeb — web technology/service identification (workbook p.3).
- curl — HTTP headers, application responses, route testing and connectivity verification.
- WAFW00F — WAF fingerprinting; evidence identified LiteSpeed/WAF behavior.
- DNSRecon — DNS enumeration.
- theHarvester — open-source intelligence/domain enumeration.
- Gobuster — directory and PDF-extension enumeration.
- Browser/Firefox and HTML inspection — patient portal mapping and response analysis.
- sqlmap — constrained automated SQL-injection check against the login username parameter.

- Hydra — bounded credential testing against one validated username using the supplied list.
- NetworkWalks Hash Calculator — extraction of crackable PDF hashes.
- NetworkWalks Password Cracker — dictionary-based PDF password recovery.

Important testing observation

The earlier sqlmap check reported that the tested username parameter did not appear injectable. The later successful manual test demonstrates why a negative automated result should not be interpreted as proof that an authentication function is secure; the successful condition was identified through direct application-behavior testing. The exact backend SQL query was not independently verified, so the report describes the result as an authentication-bypass SQL injection rather than asserting a specific unseen query.

5. Chronological Testing Narrative

Stage	Activity / Result	Evidence
5.1 Reconnaissance	WHOIS, DNS and web-technology checks established the target, DNS resolution and web stack. WhatWeb identified HTTP/LiteSpeed behavior; WAFW00F identified LiteSpeed/WAF characteristics.	Workbook pp.1–6
5.2 Application mapping	The public site exposed a Patient Portal. Gobuster and direct requests identified patient routes, including login and the reports area.	Workbook pp.7–25
5.3 Authentication analysis	The login form was inspected as a POST form with username/password inputs. Different failure messages allowed username enumeration.	Workbook pp.13–15 and later validation evidence
5.4 Reports-area testing	Direct access to the reports path initially returned restricted/403 behavior. Download-route behavior was also inspected.	Workbook pp.17, 19, 21–22, 31–33
5.5 Automated SQLi check	A constrained sqlmap test was run against the username parameter and did not identify injection.	Workbook pp.79–80

5.6 Manual SQLi success	After instructor guidance, a simple manual authentication-bypass input using `admin'--` in the username field and a non-empty password successfully authenticated to the portal. This was the turning point that completed M1.	Final completion update; post-authentication evidence: workbook p.89
5.7 Three PDFs retrieved	The authenticated My Reports page displayed three pathology reports and the three corresponding PDF files were downloaded into Kali.	Workbook pp.89–90
5.8 M2 hash extraction and cracking	Each encrypted PDF was processed through the Hash Calculator to extract a crackable `\$pdf\$` hash. Dictionary attacks then recovered the passwords.	Workbook pp.91–99
5.9 Decrypted files opened	All three PDFs were successfully opened after password recovery, demonstrating successful M2 completion.	Workbook pp.93, 96 and 101
5.10 M3 analysis	An exposed SQL backup was accessible over HTTP, downloaded locally, and queried for staff/shareholder structures and records.	Workbook pp.46–50

6. M1 — Initial Access and Retrieval of Three Patient PDFs

M1 required gaining access to a restricted area of the site and retrieving three confidential patient laboratory-report PDFs. The project brief specifically directed the tester to analyze authentication behavior and weaknesses in user-input handling.

6.1 What did not work

- Direct access to `/patient/reports/` returned HTTP 403 during earlier testing.
- Directory enumeration identified the reports location but did not directly expose the required files.
- A constrained sqlmap test against the username parameter reported that the parameter did not appear injectable.
- A bounded Hydra test was attempted against one validated username. It stopped after 12 attempts when connectivity was lost and therefore was not a completed password audit.

- The target subsequently became unreachable from the Kali environment during the earlier test window.

6.2 What ultimately worked — manual SQL injection

Following instructor guidance, the authentication function was tested manually with a simple SQL-injection authentication-bypass payload. The username input used was `admin'--`, while the password field contained a non-empty value. The application accepted the request and established an authenticated patient-portal session. The precise server-side SQL statement is not directly visible in the evidence; however, the observed result is consistent with unsafe construction of an authentication query from unparameterized user input.

Finding M1-F01 — Authentication bypass via SQL injection

Severity: CRITICAL. The login control accepted crafted SQL syntax and allowed authentication without knowledge of a legitimate account password. Because the resulting session exposed confidential patient reports, the impact extends beyond simple login bypass to unauthorized access to sensitive information.

6.3 Post-authentication proof

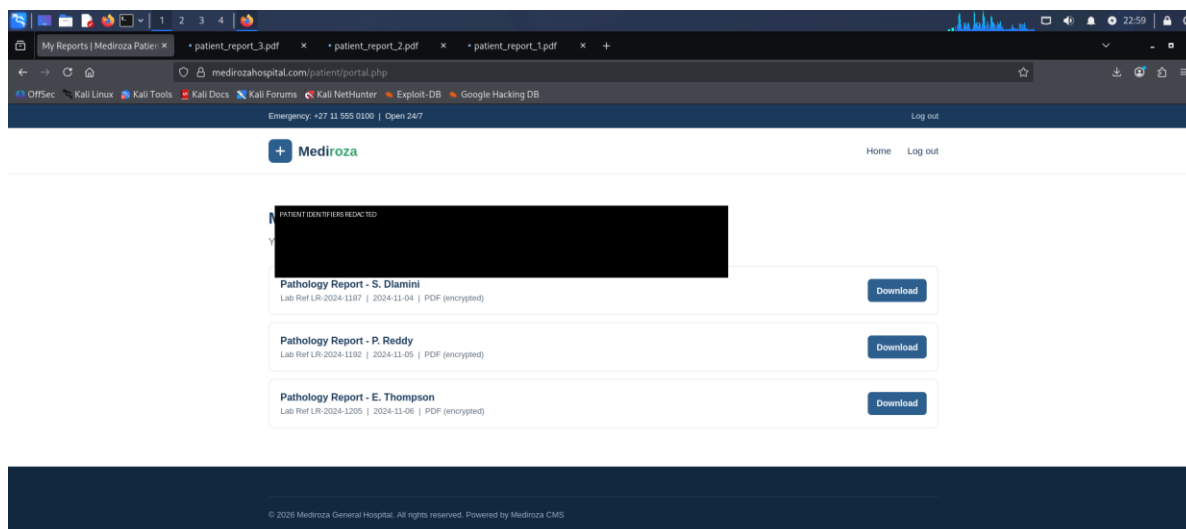


Figure 1 — Authenticated “My Reports” page showing three available laboratory-report downloads. Patient identifiers are irreversibly redacted.

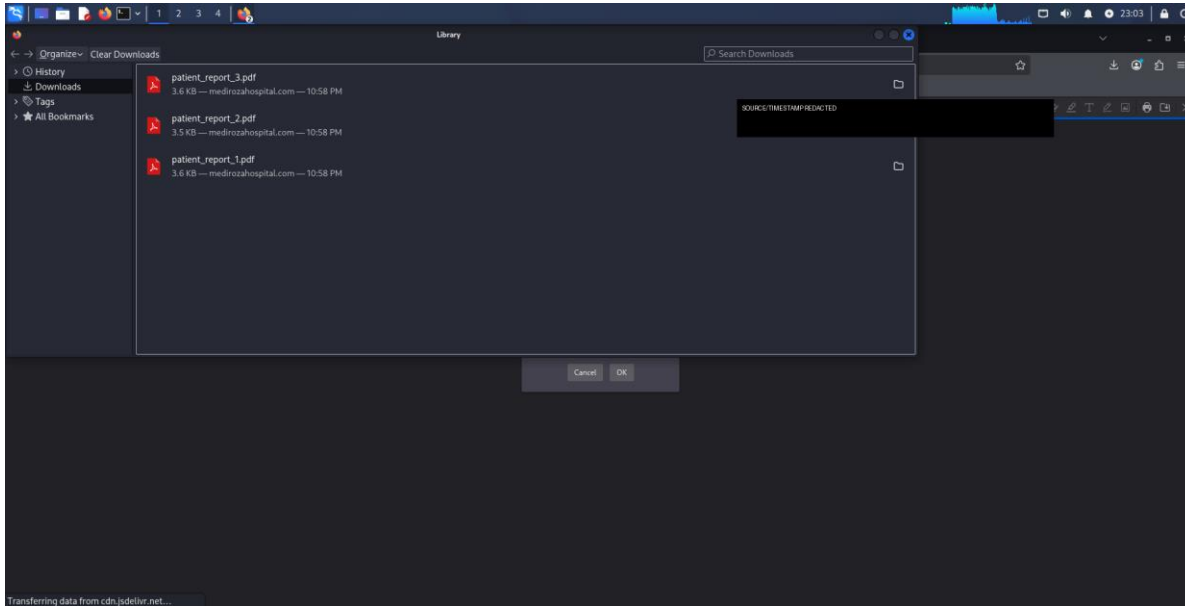


Figure 2 — Kali download evidence showing the three retrieved PDF artifacts. Unnecessary source/timestamp details are redacted.

7. M2 — PDF Password Recovery and Data Extraction

M2 required cracking the encryption on all three retrieved PDF files. The project brief explicitly cautioned that different files might require different approaches and required proof of successful access.

7.1 Hash extraction

Each downloaded PDF was loaded into the Hash Calculator. The tool identified the files as encrypted and produced crackable `\$pdf\$`-format hashes suitable for dictionary-based password recovery. The hashes themselves are not reproduced here.

7.2 Dictionary password recovery

The NetworkWalks Password Cracker was used to perform dictionary attacks against the extracted PDF hashes. The evidence records successful matches for all three PDFs. Recovered passwords are intentionally withheld from the client-facing report and are blacked out in the screenshots.

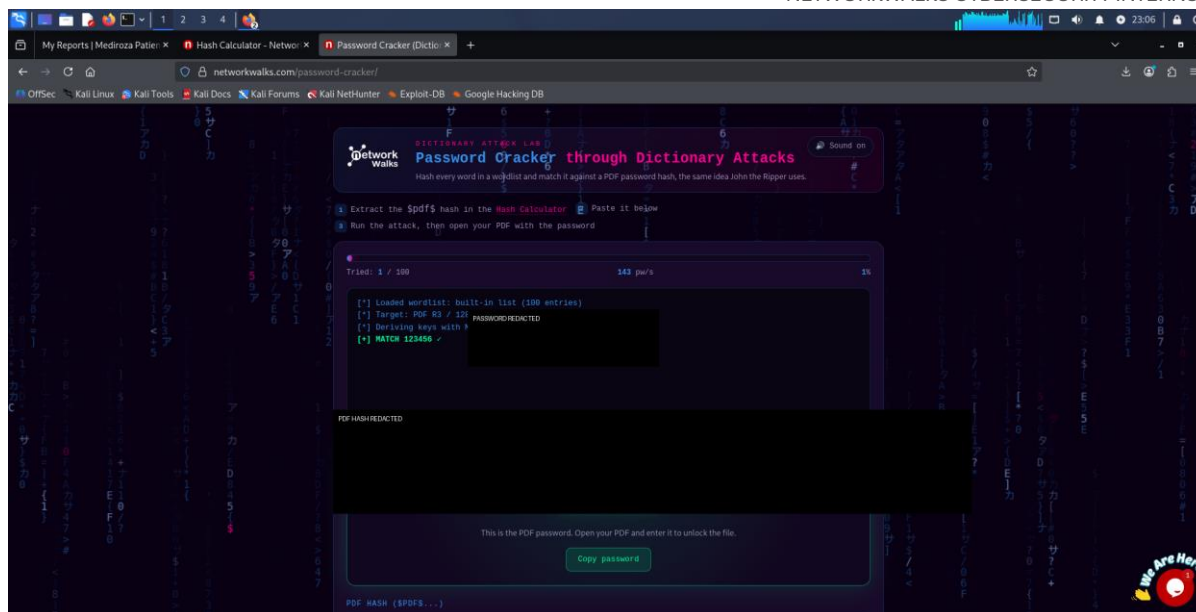


Figure 3 — PDF 1: dictionary attack reached a successful password match; password and hash redacted.

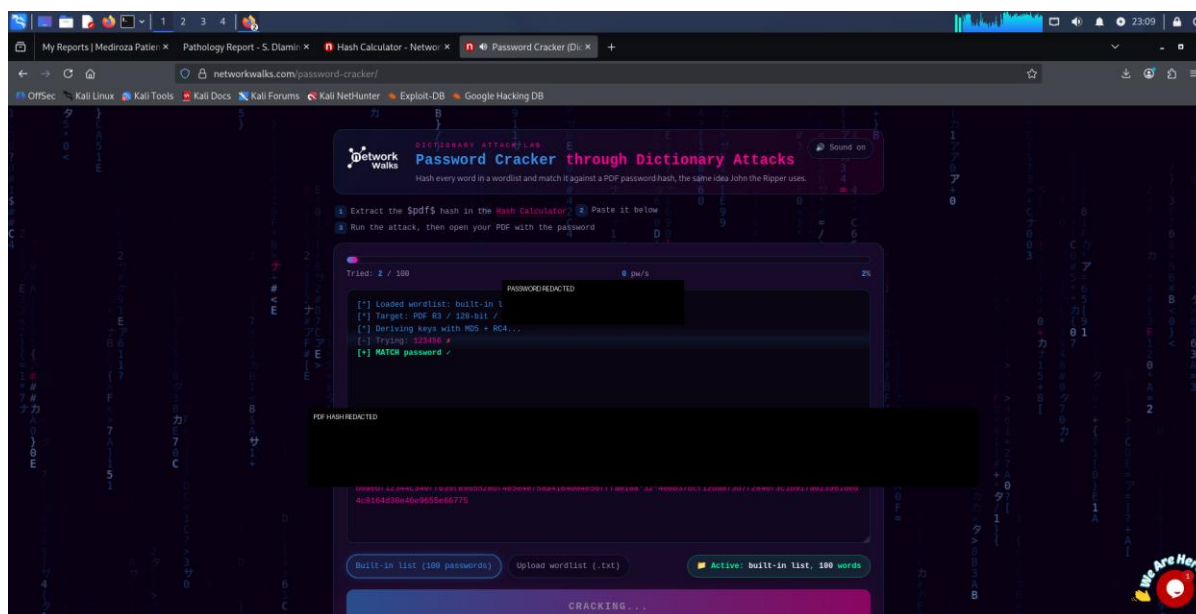


Figure 4 — PDF 2: dictionary attack reached a successful password match; password and hash redacted.

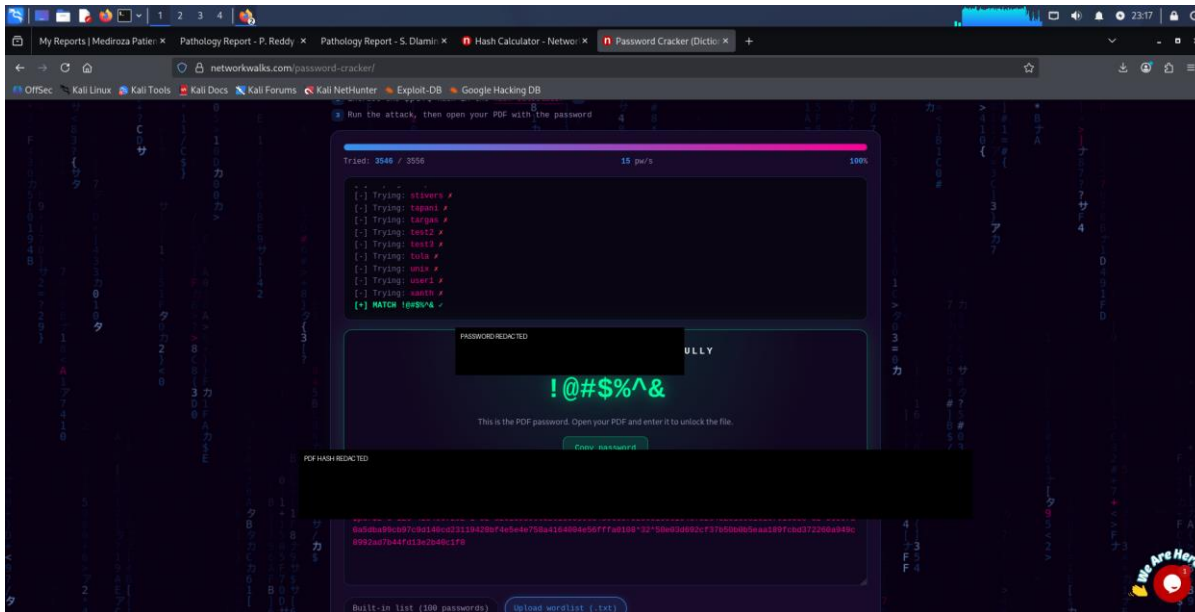


Figure 5 — PDF 3: dictionary attack completed with a successful password match; password and hash redacted.

7.3 Proof that all three PDFs were unlocked

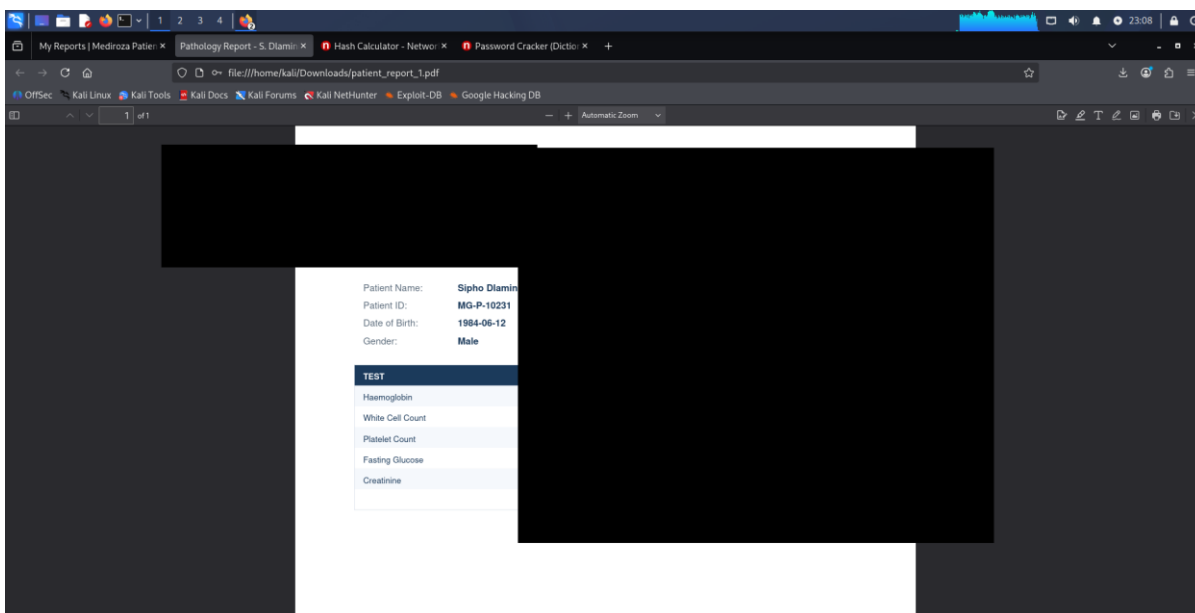


Figure 6 — PDF 1 opened successfully after password recovery; patient/clinical content redacted.

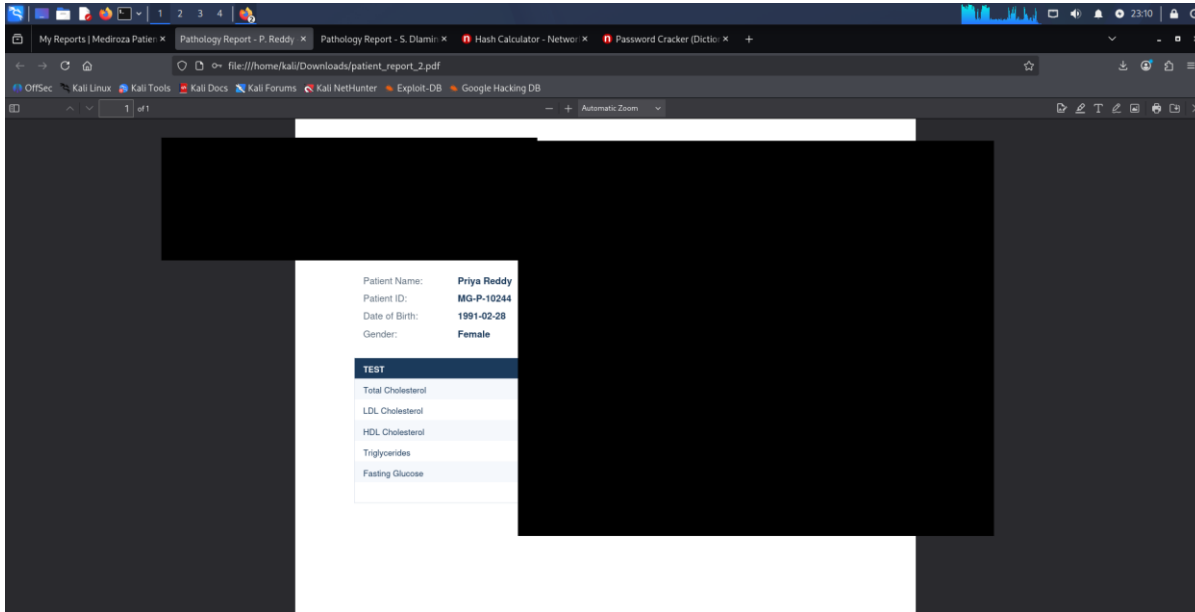


Figure 7 — PDF 2 opened successfully after password recovery; patient/clinical content redacted.

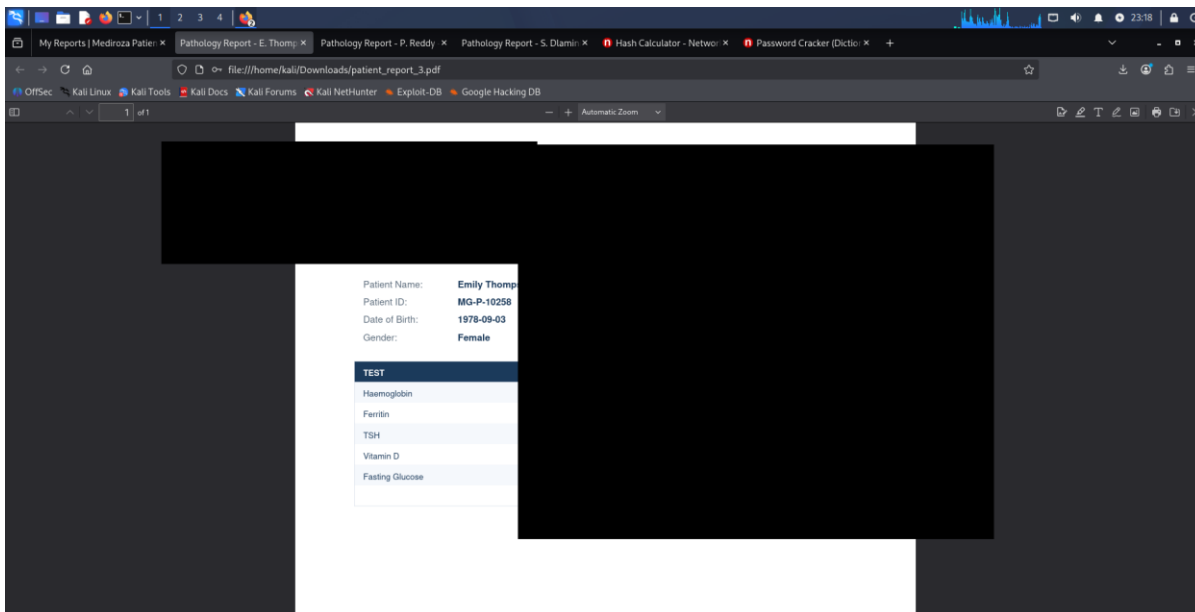


Figure 8 — PDF 3 opened successfully after password recovery; patient/clinical content redacted.

M2 Result — COMPLETED

All three encrypted patient-report PDFs were successfully recovered and opened. The report does not reproduce patient names, identifiers, dates of birth, clinical results or recovered passwords.

8. M3 — Critical Database Exposure

M3 required discovery of employee salaries and shareholder details. The evidence established that an SQL database backup was directly retrievable from a web-accessible location. The backup was then downloaded and examined locally.

8.1 M3-F01 — Publicly accessible database backup

A request to the backup resource returned HTTP 200 with an SQL content type, demonstrating that the database backup was served directly over the web. The file was subsequently downloaded into the authorized Kali evidence directory.

```

kali@kali:~$ curl -I https://medirozahospital.com/old/mediroza_db_backup_2019.sql
HTTP/2 200
content-type: text/x-sql
last-modified: Fri, 04 Sep 2020 02:02:11 GMT
accept-ranges: bytes
content-length: 6340
date: Sat, 05 Sep 2020 14:38:22 GMT
server: LiteSpeed
x-turbo-charged-by: LiteSpeed

kali@kali:~$ mkdir -p ~/Mediroza-MI/evidence

kali@kali:~$ curl -o https://medirozahospital.com/old/mediroza_db_backup_2019.sql \
-o ~/Mediroza-MI/evidence/mediroza_db_backup_2019.sql

kali@kali:~$ ls -lh ~/Mediroza-MI/evidence
-rw-rw-r-- 1 kali kali 6.2K 5

kali@kali:~$ head -n 48 ~/Mediroza-MI/ev
-- mediroza_db_backup_2019.sql
-- Mediroza General Hospital - Internal database backup
-- Generated by Mediroza CMS
-- Host: localhost   Database: mediroza_hr
-- WARNING: contains confidential staff and shareholder records
-- Backup date: 2019-08-27 02:02:11

SET NAMES utf8mb4;
SET FOREIGN_KEY_CHECKS = 0;

--
-- Table structure for table
--
DROP TABLE IF EXISTS `staff`;
CREATE TABLE `staff` (
  `id` int(11) NOT NULL AUTO_INCREMENT,
  `full_name` varchar(120) NOT NULL,
  `job_title` varchar(120) NOT NULL,
  `department` varchar(80) NOT NULL,
  `email` varchar(120) NOT NULL,
  `phone` varchar(20) NOT NULL,
  `national_id` varchar(20) NOT NULL,
  `monthly_salary_zar` int(12) NOT NULL,
  `date_joined` date NOT NULL,
  PRIMARY KEY (`id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;

```

Figure 9 — HTTP 200 response for the exposed SQL backup; unnecessary backup details redacted.

```

kali@kali:~$ mkdir -p ~/Mediroza-MI/evidence

kali@kali:~$ curl -o https://medirozahospital.com/old/mediroza_db_backup_2019.sql \
-o ~/Mediroza-MI/evidence/mediroza_db_backup_2019.sql

kali@kali:~$ ls -lh ~/Mediroza-MI/evidence/mediroza_db_backup_2019.sql
-rw-rw-r-- 1 kali kali 6.2K Sep 5 10:39 /home/kali/Mediroza-MI/evidence/mediroza_db_backup_2019.sql

kali@kali:~$ head -n 48 ~/Mediroza-MI/evidence/mediroza_db_backup_2019.sql
-- mediroza_db_backup_2019.sql
-- Mediroza General Hospital - Internal database backup
-- Generated by Mediroza CMS 1.4.2 backup module
-- Host: localhost   Database: mediroza_hr
-- WARNING: contains confidential staff and shareholder records
-- Backup date: 2019-08-27 02:02:11

SET NAMES utf8mb4;
SET FOREIGN_KEY_CHECKS = 0;

--
-- Table structure for
--
DROP TABLE IF EXISTS `staff`;
CREATE TABLE `staff` (
  `id` int(11) NOT NULL,
  `full_name` varchar(120) NOT NULL,
  `job_title` varchar(120) NOT NULL,
  `department` varchar(80) NOT NULL,
  `email` varchar(120) NOT NULL,
  `phone` varchar(20) NOT NULL,
  `national_id` varchar(20) NOT NULL,
  `monthly_salary_zar` int(12) NOT NULL,
  `date_joined` date NOT NULL,
  PRIMARY KEY (`id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;

--
-- Dumping data for table
--
LOCK TABLES `staff` WRITE;
INSERT INTO `staff` (`id`, `full_name`, `job_title`, `department`, `email`, `phone`, `national_id`, `monthly_salary_zar`, `date_joined`) VALUES
(1, 'Dr. Rajesh Mishra', 'Chief Pathologist', 'Diagnostics Lab', 'r.mishra@medirozahospital.com', '+27 82 183 2807', '85081013011081', 135000, '2009-03-16'),
(2, 'Sarah Botha', 'Chief Financial Officer', 'Finance', 's.botha@medirozahospital.com', '+27 82 182 2814', '85081023022082', 152000, '2011-07-01'),
(3, 'Dr. John van der Merwe', 'Medical Director', 'Management', 'j.vandermerwe@medirozahospital.com', '+27 82 185 2021', '85048102303083', 160000, '2007-01-22'),
(4, 'Dr. Anita Mallick', 'Consultant Cardiologist', 'Cardiology', 'a.mallick@medirozahospital.com', '+27 82 186 2025', '850510304084', 132000, '2012-09-10'),
(5, 'Dr. Ahmed Kara', 'Consultant Physician', 'Internal Medicine', 'a.kara@medirozahospital.com', '+27 82 185 2035', '85061051055085', 120000, '2013-02-18'),
(6, 'Dr. Yusuf Cassim', 'Senior Registrar', 'Emergency & Trauma', 'y.cassim@medirozahospital.com', '+27 82 186 2042', '85071061066086', 74000, '2015-03-04'),
(7, 'Michael Roberts', 'HR Director', 'Human Resources', 'm.roberts@medirozahospital.com', '+27 82 187 2049', '85081073077087', 96000, '2010-11-15'),
(8, 'Susan Pretorius', 'HR Officer', 'Human Resources', 's.pretorius@medirozahospital.com', '+27 82 188 2056', '85091081088088', 32000, '2016-08-23');

```

Figure 10 — Local retrieval of the exposed database backup; unnecessary local path/data details redacted.

8.2 M3-F02 — Sensitive staff information exposed

The staff table contained fields for identity, job role, department, email, telephone number, national identification, monthly salary and date joined. The exercise evidence also showed actual records containing this information. Individual values are not reproduced in this report.

8.3 M3-F03 — Staff and shareholder structures disclosed

Schema analysis returned CREATE TABLE and INSERT structures for both staff and shareholders. The shareholder structure included fields for shareholder identity, ownership percentage, shares held and share class. Knowledge of these structures exposes the internal data model and identifies high-value datasets for further targeting.

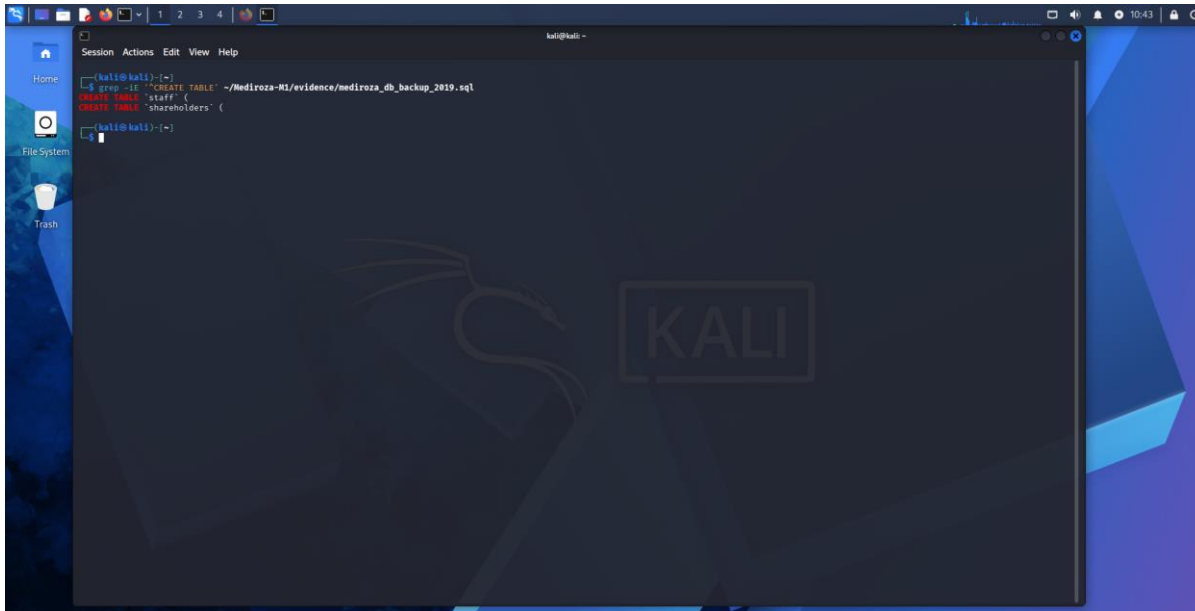


Figure 11 — Schema search showing staff and shareholder database structures.

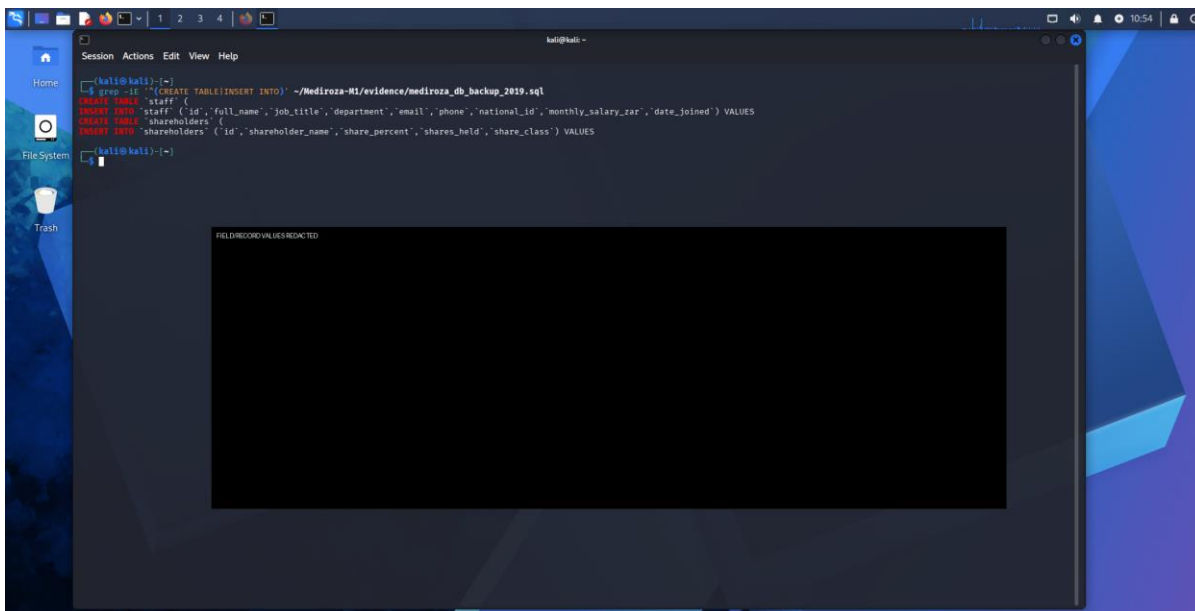


Figure 12 — Field/record structure evidence; unnecessary values are redacted.

9. Consolidated Findings and Risk Ratings

ID	Finding	Impact	Risk	Priority
----	---------	--------	------	----------

M1-F01	Authentication bypass via SQL injection	Unauthorized authentication and access to confidential patient reports	CRITICAL	Immediate
M3-F01	Publicly accessible SQL database backup	Direct exposure of application/database data	HIGH	Immediate
M3-F02	Sensitive staff and salary information in exposed backup	Severe privacy/confidentiality impact	CRITICAL	Immediate
M3-F03	Staff/shareholder schema and data structures disclosed	Enables targeted follow-on attacks and reveals high-value datasets	HIGH	High
M1-F02	Username enumeration through differentiated login responses	Reduces account-search space for credential attacks	MEDIUM	High

10. Recommendations and Remediation

10.1 Fix the SQL injection — immediate

Use parameterized/prepared SQL statements for every authentication query. Never concatenate username or password input into SQL. Validate inputs server-side and ensure the authentication logic compares securely against stored password hashes. Add regression tests specifically covering quote characters, comment syntax and common authentication-bypass payloads.

10.2 Protect patient reports — immediate

Require robust server-side authorization for every report-download request. Do not rely on hidden links or predictable file names. Bind each report to the authenticated patient/account and verify authorization before serving the file. Store report files outside the public web root where practical.

10.3 Remove public database backups — immediate

Delete SQL dumps, archives and backup artifacts from web-accessible directories. Store backups outside the web root and enforce access controls at the storage layer and web-server layer.

10.4 Treat exposed backup contents as compromised

Review the training environment for copied backup files, rotate or invalidate any credentials/secrets contained within them, and review access logs where available.

10.5 Encrypt and segregate backups

Encrypt backups at rest, maintain keys separately, restrict backup access by role and network, and regularly test restoration without exposing backup files through the application server.

10.6 Improve authentication responses

Return a generic failure message for invalid usernames and invalid passwords. Add sensible throttling, monitoring and alerting for repeated failed authentication attempts.

10.7 Re-test after remediation

Repeat M1 authentication testing, report authorization/download testing and direct backup-path checks. Confirm that the old SQL injection no longer changes authentication behavior and that no backup artifacts remain publicly reachable.

11. Testing Limitations and Lessons Learned

- The earlier connectivity interruption prevented completion of the initial bounded Hydra run; this was not treated as a successful password crack.
- The automated sqlmap test did not identify the later successful manual authentication bypass. This is a limitation of relying on a narrow-automated test rather than evidence that the application was safe.
- The report does not infer the exact server-side SQL query because the backend source was not available in the black-box assessment.
- Patient data, staff personal information, national identifiers, salary values, shareholder values, passwords and PDF hashes have been intentionally omitted or redacted from the report.
- M3 was completed before M1/M2 were ultimately completed; the final report records the actual discovery order rather than presenting the milestones as if they occurred sequentially.

12. Evidence Handling and Redaction

The complete screenshot workbook is retained separately as the primary chronological evidence artifact. This final report uses selected screenshots that demonstrate the attack path and successful milestone completion while minimizing unnecessary exposure of confidential information. The original evidence workbook contains additional screenshots and raw values that are not reproduced here.

- Black-box redaction: sensitive pixels are replaced with opaque black blocks rather than blurred, preserving an irreversible redaction for sharing.
- Patient names, patient identifiers, dates of birth, clinical results and other medical content are redacted.
- Recovered PDF passwords and crackable PDF hashes are redacted.
- Staff personal data, national identifiers, contact details and salary values are redacted.

- Where a screenshot is retained only to prove a technical state (for example HTTP 200, successful match or successful PDF opening), unrelated screen content is redacted or omitted.

13. Evidence Register

Evidence ID	Description	Purpose	Source
M1-E01	Authenticated My Reports page	Proof of successful authenticated access and availability of three reports	Workbook p.89
M1-E02	Three PDF downloads	Proof that all three required PDF files were retrieved	Workbook p.90
M1-E03	Patient login form / application structure	Proof of authentication attack surface	Workbook pp.13–15, 23, 25
M1-E04	Username enumeration	Proof of differentiated login responses	Workbook pp.14 and 81
M1-E05	Automated SQLi check	Documents unsuccessful constrained sqlmap result	Workbook pp.79–80
M2-E01	PDF 1 successful crack	Proof of password recovery	Workbook p.92
M2-E02	PDF 2 successful crack	Proof of password recovery	Workbook p.95
M2-E03	PDF 3 successful crack	Proof of password recovery	Workbook p.99
M2-E04–06	Three opened PDFs	Proof all three decrypted files were opened	Workbook pp.93, 96, 101
M3-E01	SQL backup HTTP 200	Proof backup was directly retrievable	Workbook p.46
M3-E02	Backup download	Proof local acquisition of exposed backup	Workbook p.47
M3-E03	Schema search	Proof staff/shareholder structures existed	Workbook pp.48–49
M3-E04	Sensitive staff records	Proof sensitive fields/records existed	Workbook p.50 and related evidence

14. Appendix A — Selected Redacted Evidence

The following figures are sanitized reproductions of the original evidence workbook. The workbook page number is retained in each caption so the instructor can reconcile the sanitized evidence with the complete evidence set.

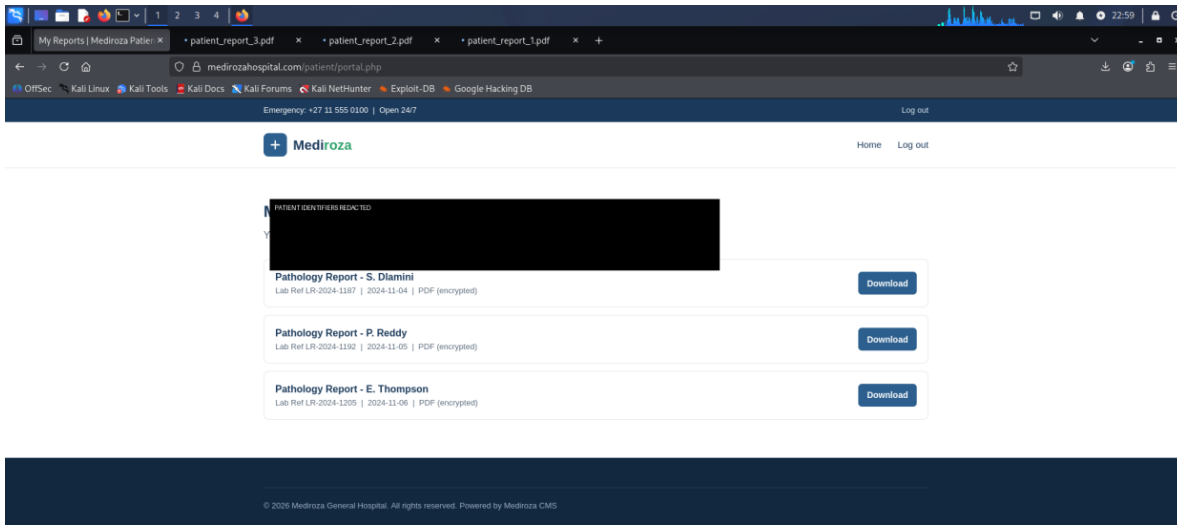


Figure 1 — Workbook p.89: authenticated reports page.

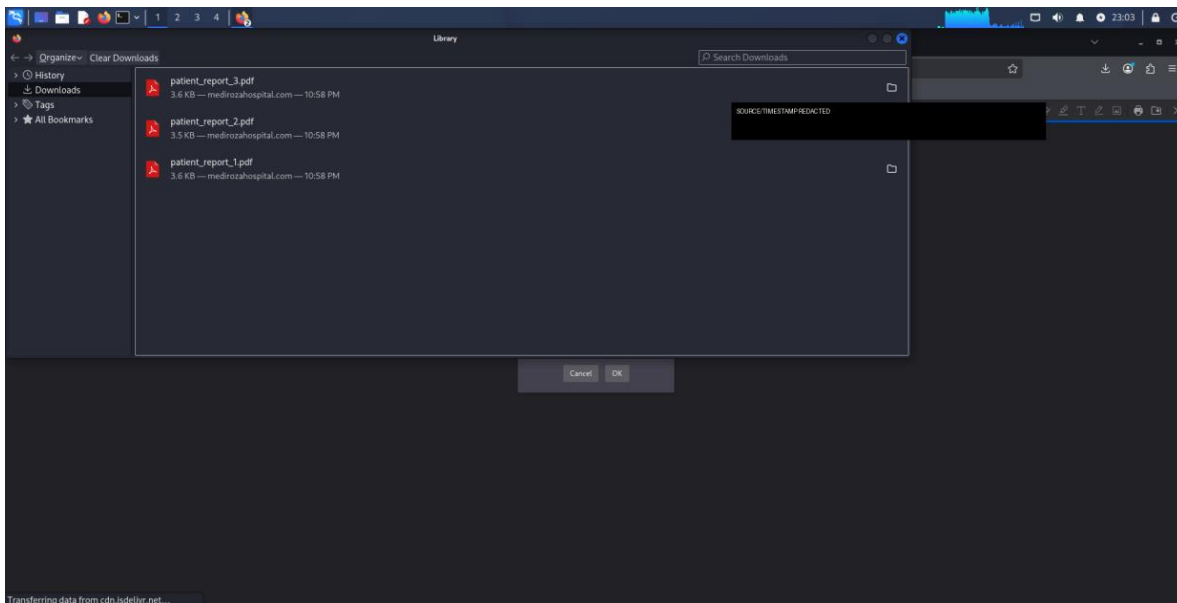


Figure 2 — Workbook p.90: three downloaded PDF artifacts.

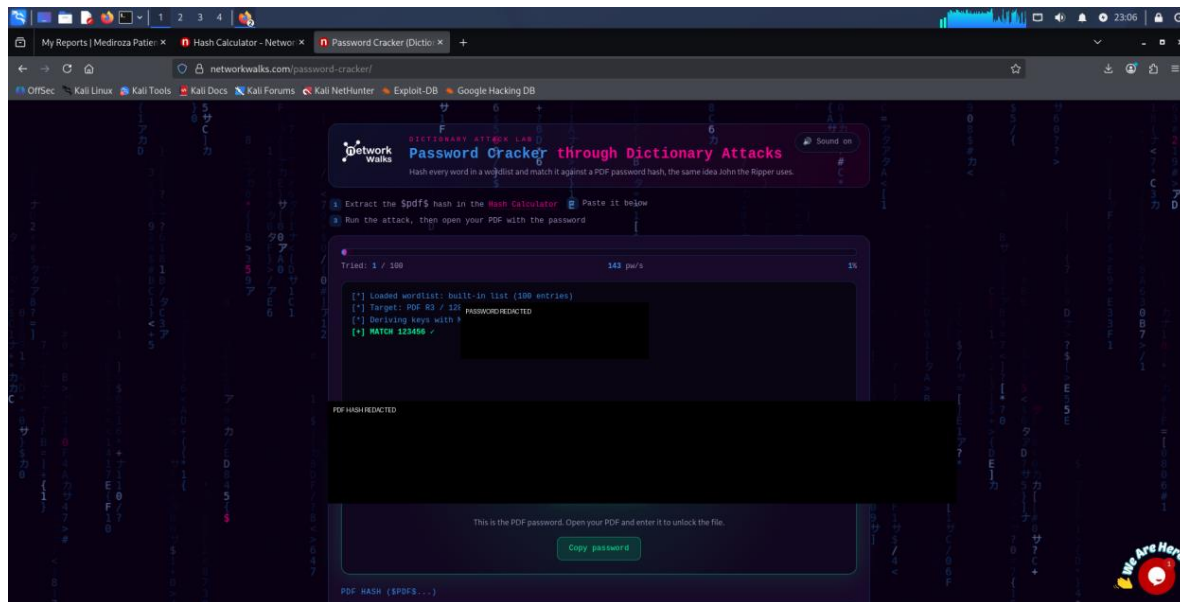


Figure 3 — Workbook p.92: PDF 1 successful crack.

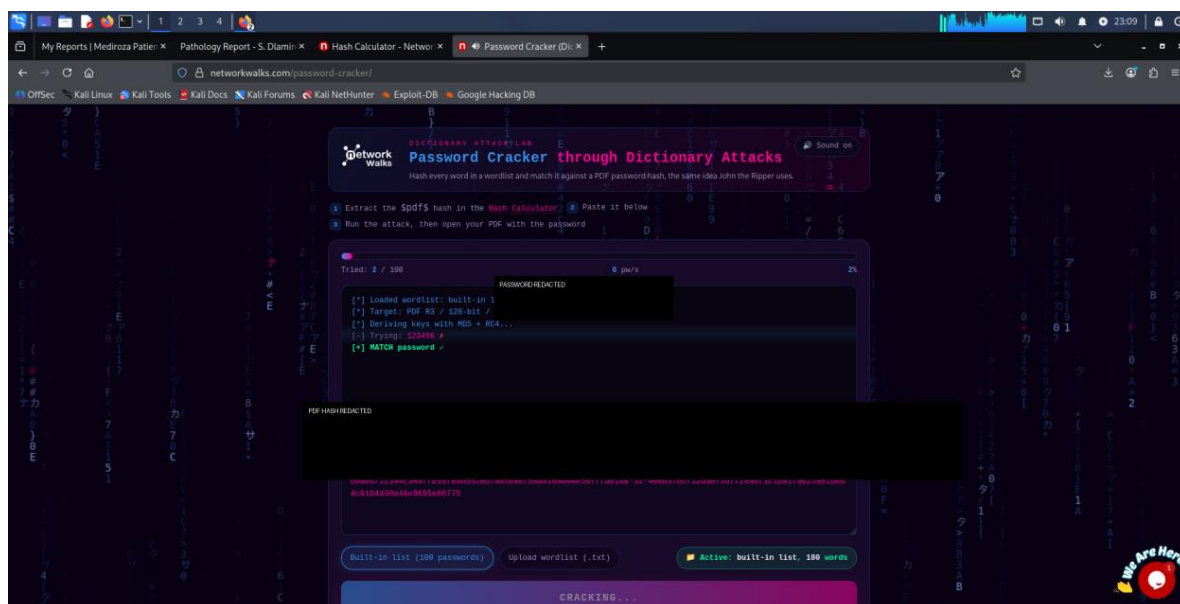


Figure 4 — Workbook p.95: PDF 2 successful crack.

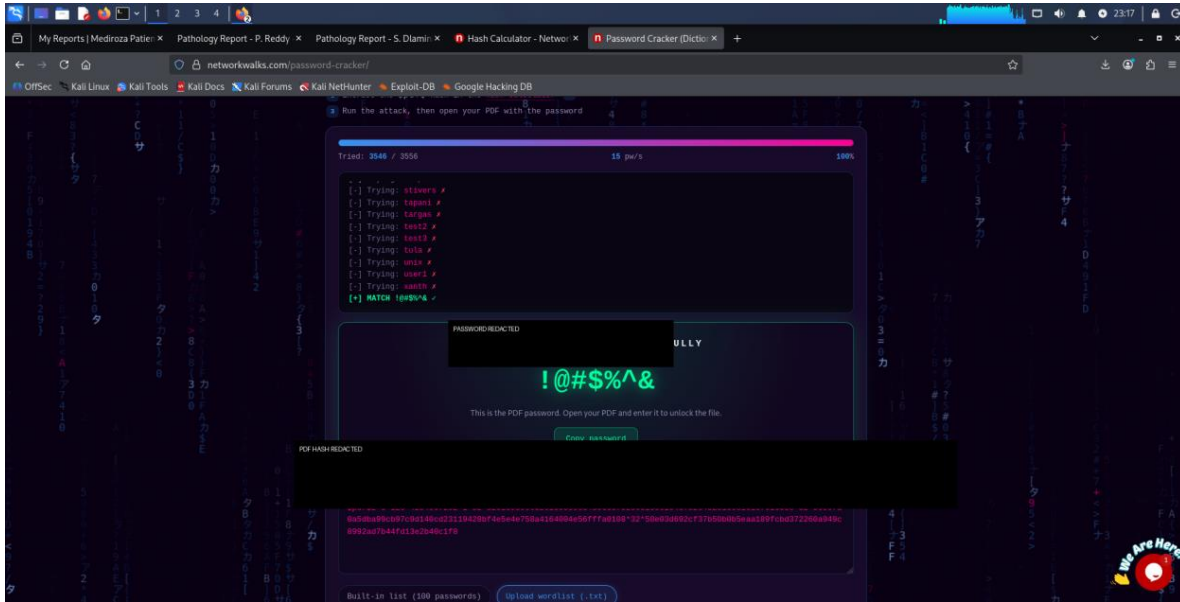


Figure 5 — Workbook p.99: PDF 3 successful crack.

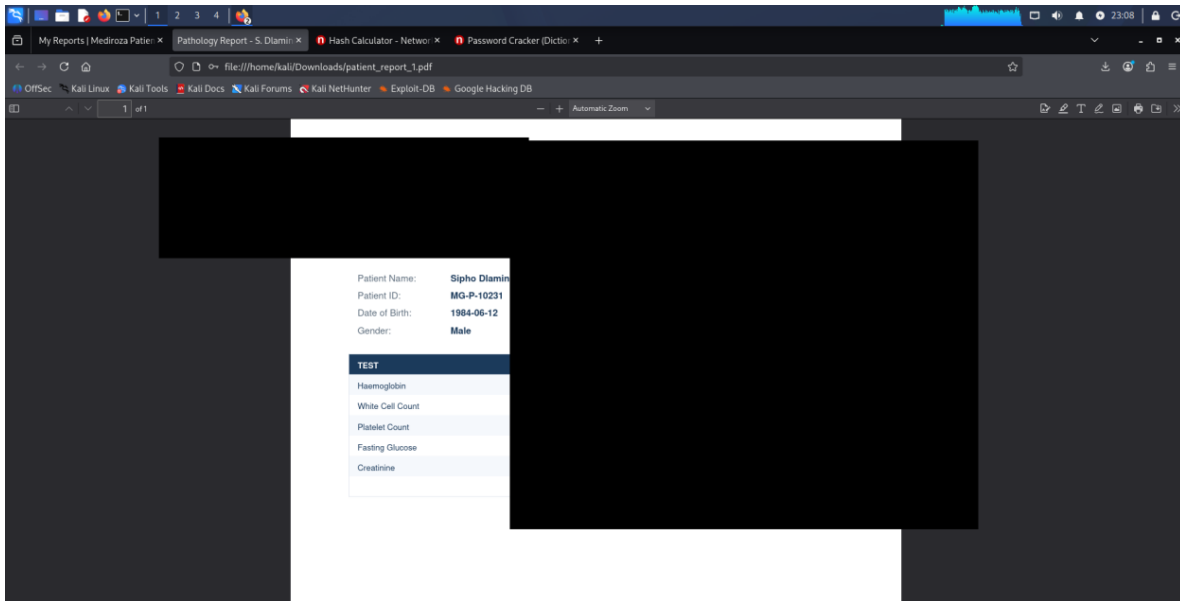


Figure 6 — Workbook p.93: PDF 1 opened.

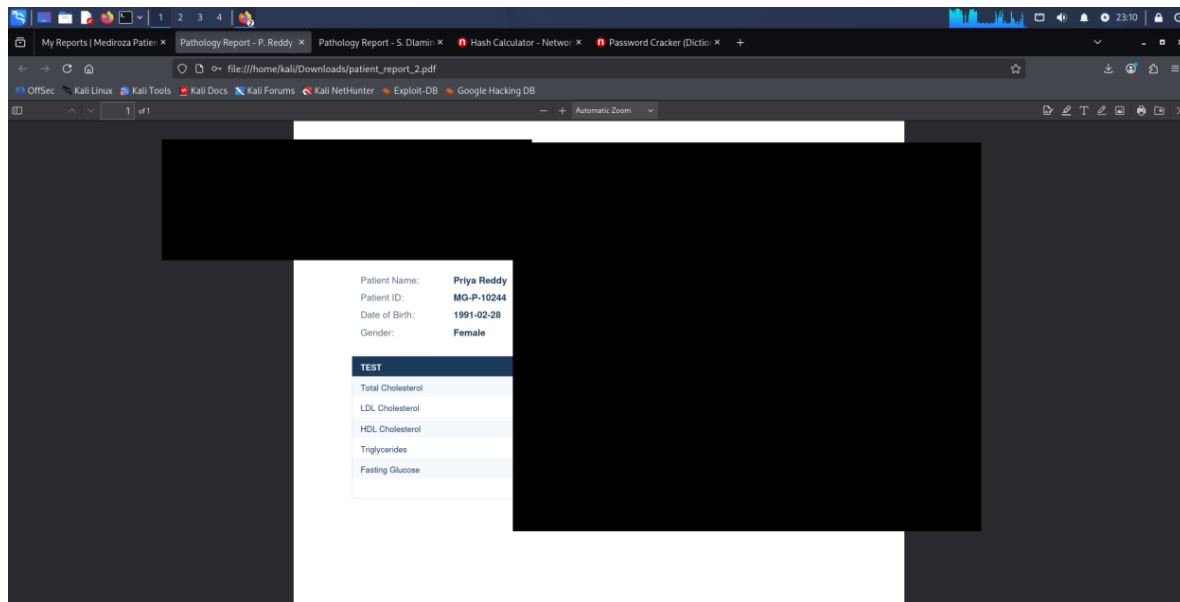


Figure 7 — Workbook p.96: PDF 2 opened.

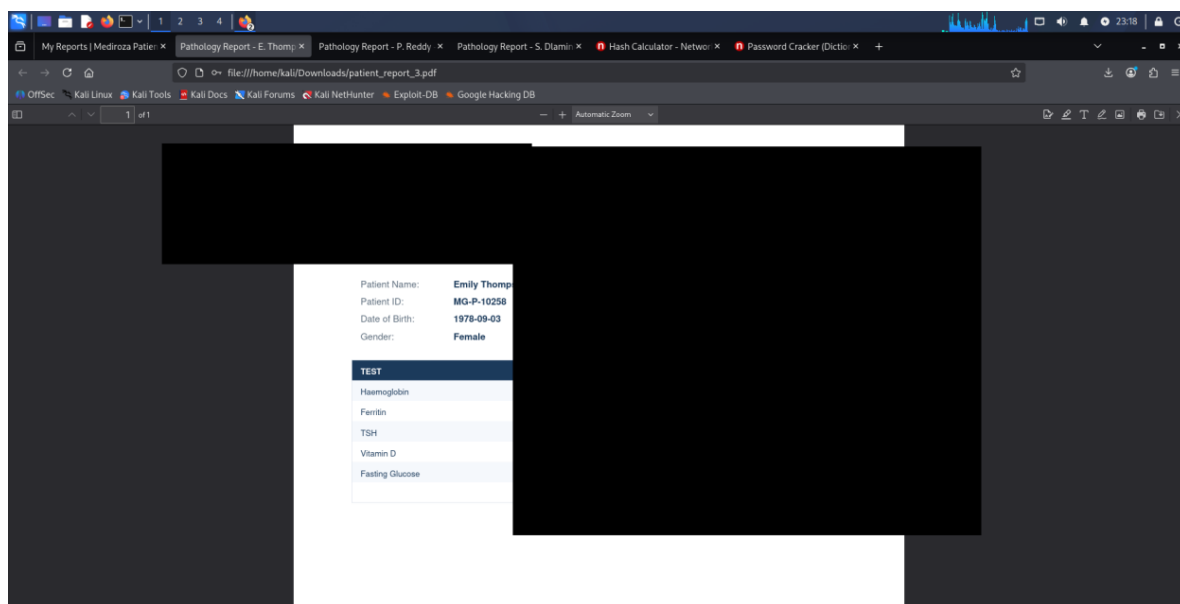


Figure 8 — Workbook p.101: PDF 3 opened.

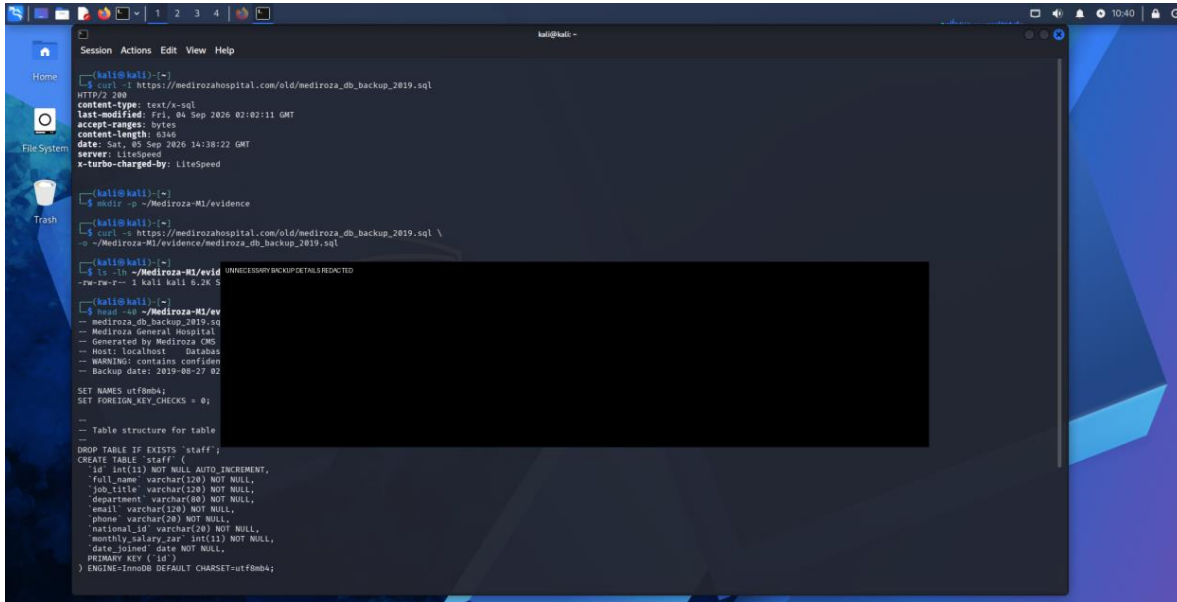


Figure 9 — Workbook p.46: exposed SQL backup HTTP 200.

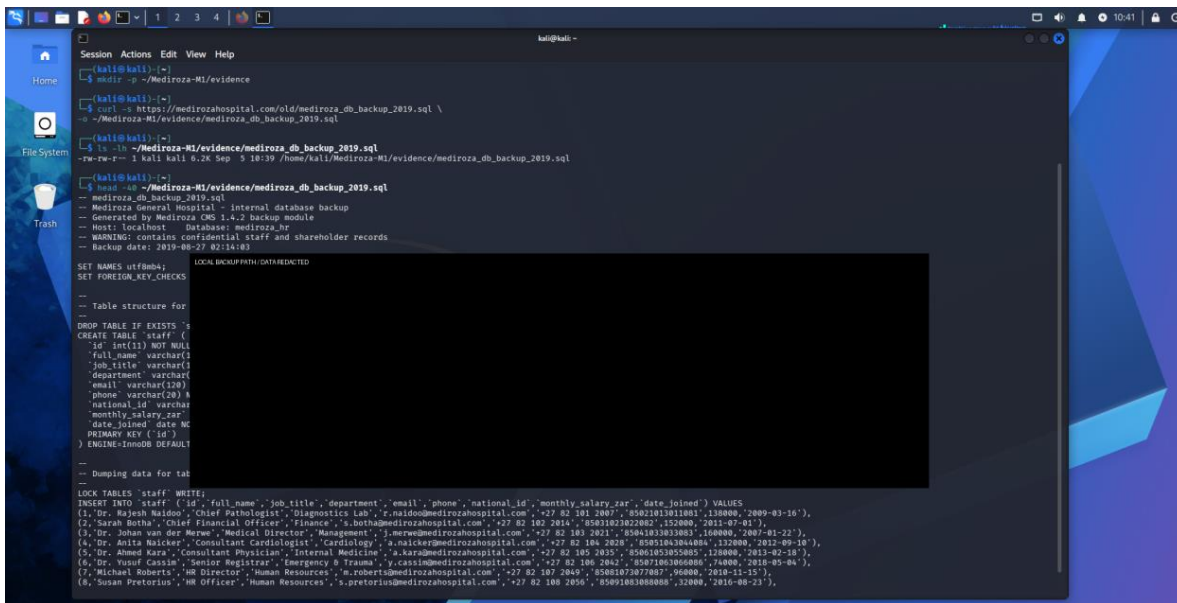


Figure 10 — Workbook p.47: backup downloaded.

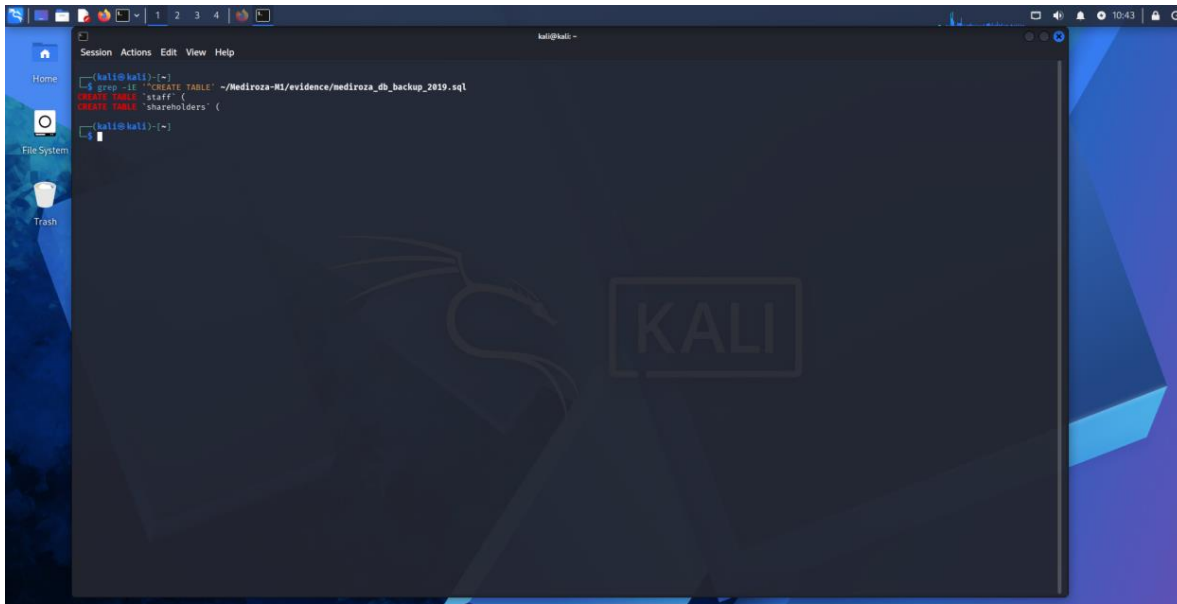


Figure 11 — Workbook p.48: staff/shareholder schema.

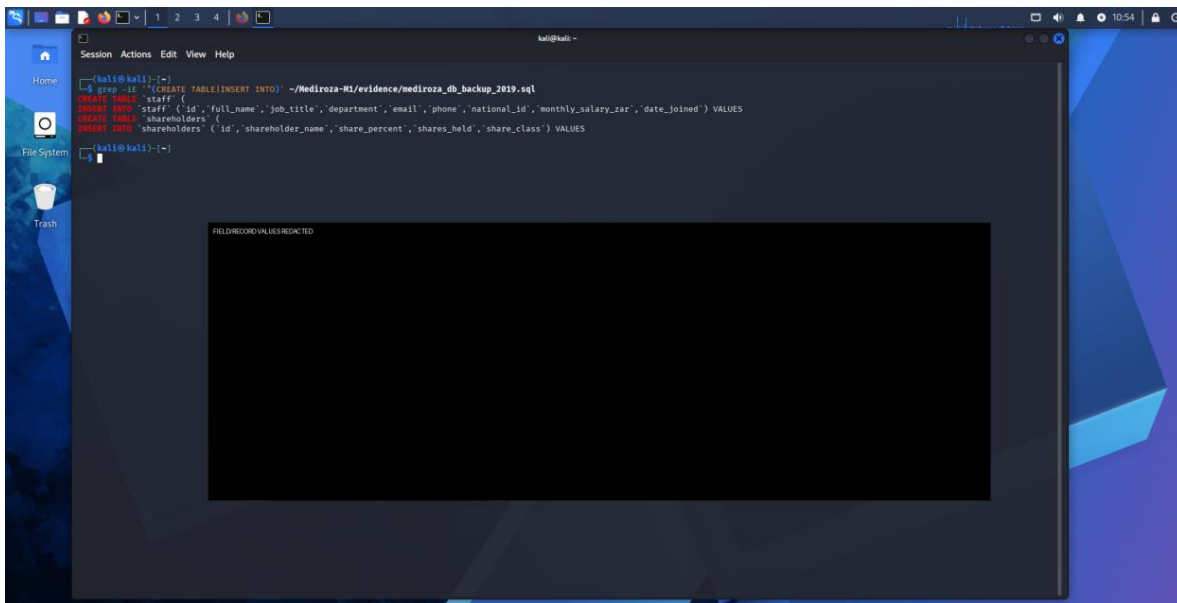


Figure 12 — Workbook p.49: schema/field structure.

15. Conclusion

The Week 4 assessment ultimately demonstrated a complete attack path from reconnaissance to unauthorized authenticated access, confidential-file retrieval, password recovery and sensitive database-data discovery. The most significant technical weakness was the authentication-bypass SQL injection, which enabled access to the patient reports. The second major weakness was the web-accessible SQL backup, which exposed highly sensitive staff information and staff/shareholder database structures. These findings meet the intent of the four Week 4 milestones and demonstrate real security impact in the authorized training environment.

The assessment also demonstrated an important penetration-testing lesson: automated tools are valuable but do not replace manual validation. The constrained sqlmap test did not flag the vulnerable username parameter, yet direct application testing later produced a successful authentication bypass. A professional assessment therefore needs to combine automated discovery with careful observation of application behavior, controlled manual testing, evidence preservation and clear documentation of both failed and successful approaches.

Final disposition

M1 — COMPLETED • M2 — COMPLETED • M3 — COMPLETED • M4 — COMPLETED

16. Training / Authorization Disclaimer

This report documents cybersecurity techniques performed within the authorized NetworkWalks training environment for educational purposes. The techniques described are dual-use and must only be applied to systems, accounts and files for which explicit authorization exists. The original project brief confirms written permission and target restrictions for this exercise.